ЗВІТ
про виконання лабораторної роботи №5
«Захищена область управління даними»
з дисципліни
«Вебтехнології»
Студента групи КН-2327Б
Багрія-Белза Андрія

Мета роботи: Реалізувати захищену область, де авторизований користувач із потрібними повноваженнями управляє даними системи: новий модуль користувачів (адмін), role-aware інтерфейс, CRUD-покрытие всіх 15 таблиць за матрицею дозволів.

Завдання 1: Новий модуль /users — лише для ролі Адміністратор: список користувачів з пошуком за ім'я, email або телефоном.

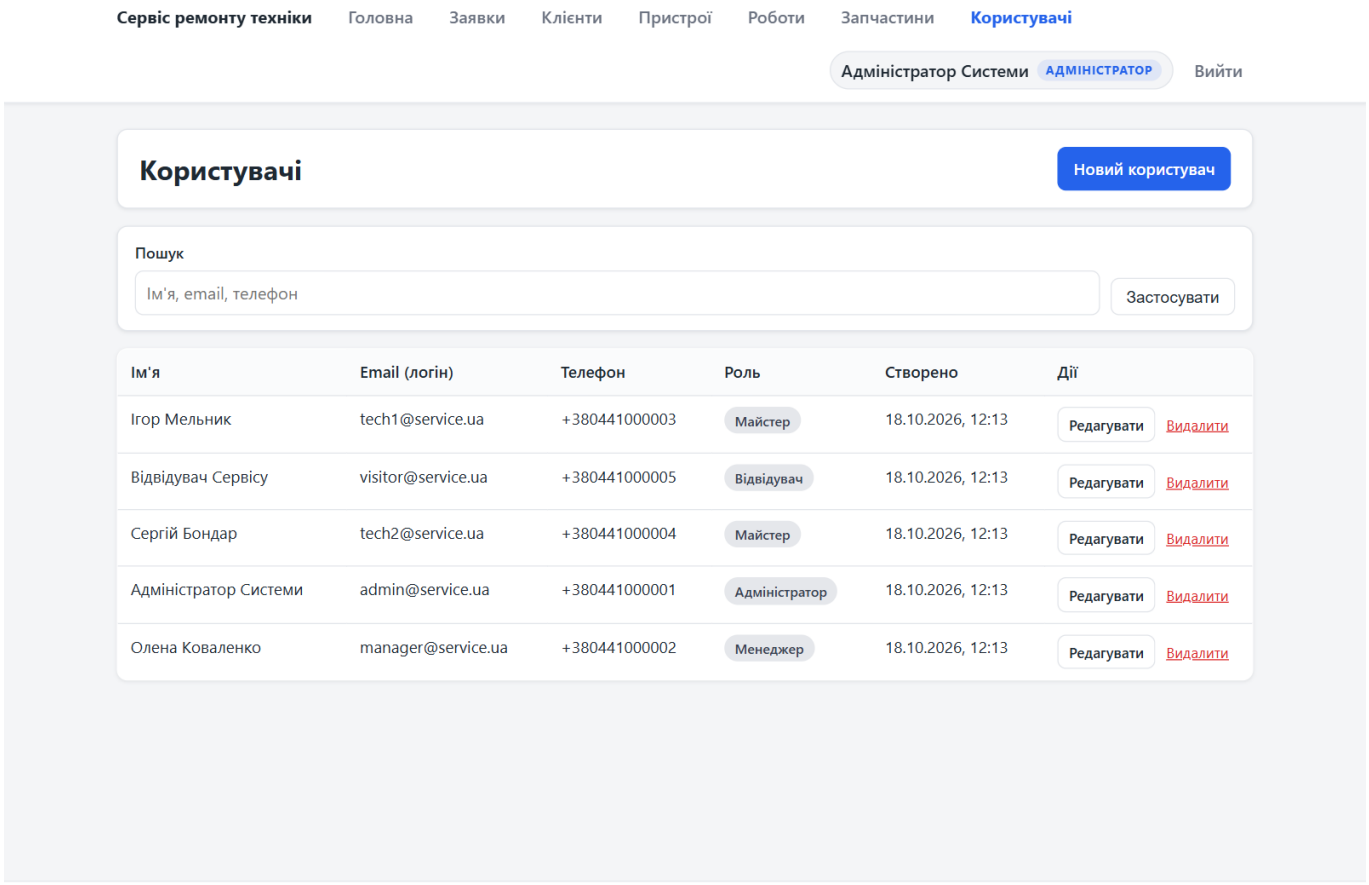
1. src/routes/users.ts — захист усього routera одним вейдером

```
import { requireRole } from "../lib/auth.js";
import * as c from "../controllers/users.js";

// Керування користувачами — лише АДМІНІСТРАТОР (матриця дозволів, Lab 5).
const router = Router();

router.use(requireRole(["ADMIN"]));

router.get("/", c.index);
router.get("/new", c.createForm);
router.post("/", c.create);
router.get("/:id/edit", c.editForm);
router.post("/:id/edit", c.edit);
router.get("/:id/delete", c.confirmRemove);
router.post("/:id/delete", c.remove);
```

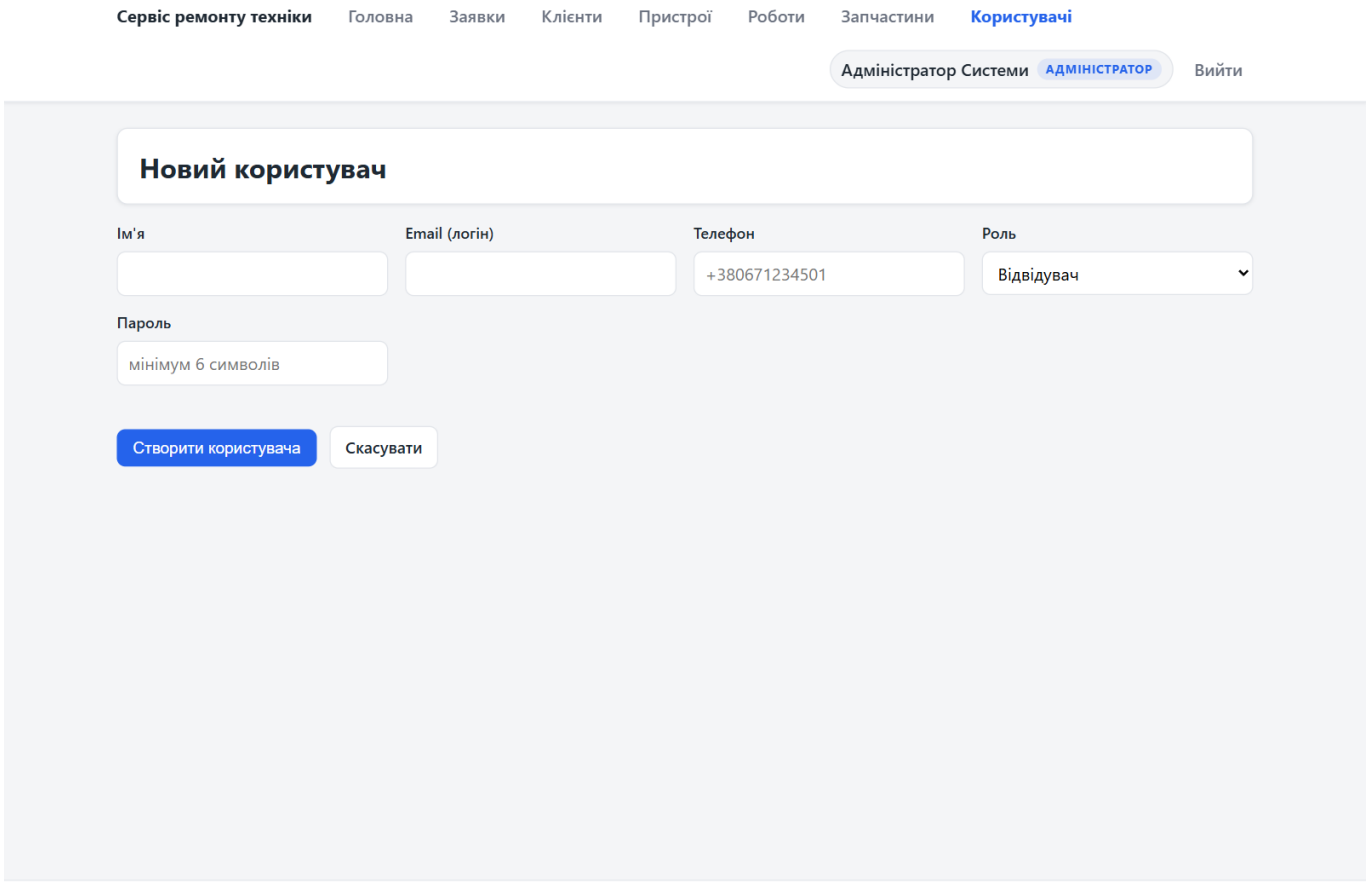


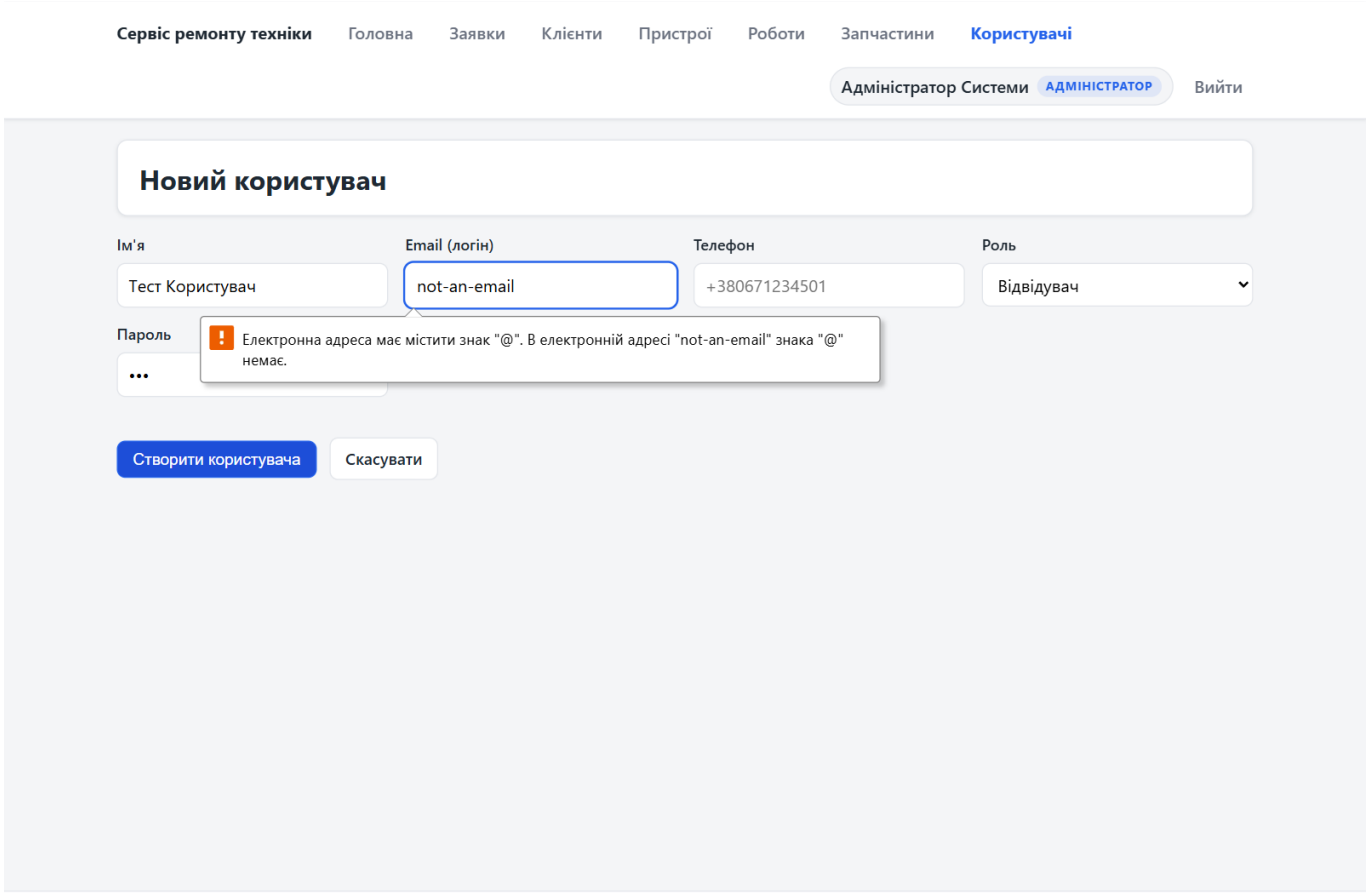
Уся область /users захищена одним middleware requireRole(["ADMIN"]) на рівні routera: менеджер, який введе /users у адресному рядку, отримує 403, а не порожню сторінку. Список показує всіх користувачів із ролями; пошук ?q= фільтрує за ім'я, email або телефоном (case-insensitive).

Завдання 2: Створення та редагування користувача: серверна валідація (ім'я, email, телефон, роль, пароль ≥ 6 символів) та унікальність email.

1. src/controllers/users.ts — серверна валідація

```
const errors: string[] = [];
if (!name) errors.push("Вкажіть ім'я");
else if (name.length < 2) errors.push("Ім'я: мінімум 2 символи");
if (!email) errors.push("Вкажіть email (логін)");
else if (!isEmail(email)) errors.push("Email: некоректний формат");
if (phone && !isPhone(phone)) errors.push("Телефон: 10–15 цифр");
if (!ROLES.includes(role as (typeof ROLES)[number])) errors.push("Оберіть роль");
if (opts.requirePassword) {
  if (!password) errors.push("Вкажіть пароль");
  else if (password.length < 6) errors.push("Пароль: мінімум 6 символів");
} else if (password && password.length < 6) {
  errors.push("Пароль: мінімум 6 символів (або залиште порожнім, щоб зберегти старий)");
}
```





Форма створення користувача і відмова за некоректними значеннями: email без «@» та короткий пароль «123» повертають статус 400 із серверним списком помилок і збереженими значеннями полів (паттерн Lab 3). Унікальність email перевіряється перехопленням P2002 (isUniqueViolation) — повторний email дає 400 «Користувач з таким email вже існує». При редагуванні порожнє поле пароля означає «зберегти старий».

Завдання 3: Безпечне видалення та role-aware керування даними: FK-обмеження (Restrict) не дають стерти користувача з історією, заборона видаляти власний акаунт, UI приховує недозволені дії.

Сервіс ремонту техніки Головна Заявки Клієнти Пристрої Роботи Запчастини

Олена Коваленко МЕНЕДЖЕР Вийти

Клієнти

Новий клієнт

Пошук

Ім'я, телефон, email

Застосувати

Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити Видалити

Ім'я / назва	Телефон	Email	Адреса	Пристрої	Заявки	Дії
Андрій Кравець	+380671234503	a.kravets@example.com	м. Київ, вул. Деснянska, 22	4	3	
Віктор Гаврилюк	+380671095028	client21@example.com	м. Ірпінь, вул. Проспект Свободи, 29	1	1	
Віктор Кравченко	+380671126704	client25@example.com	м. Мостиська, вул. Чорновола, 60	1	0	
Володимир Литвин	+380671118785	client24@example.com	м. Ірпінь, вул. Грушевського, 35	1	2	
Володимир Полтавець	+380671234508	v.poltavets@example.com	м. Київ, вул. Солом'янська, 30	2	3	
Денис Соловей	+380671079190	client19@example.com	м. Львів, вул. Січова, 74	1	2	
Дмитро Петренко	+380671007919	client10@example.com	м. Мостиська, вул. Лесі Українки, 31	1	2	
Євгенія Кравчук	+380671166299	client30@example.com	м. Київ, вул. Грушевського, 46	1	0	
Іван Марченко	+380671142542	client27@example.com	м. Вінниця, вул. Грушевського, 113	1	1	
Катерина Заруба	+380671031676	client13@example.com	м. Ірпінь, вул. Грушевського, 116	1	2	

Сервіс ремонту техніки Головна Заявки Клієнти Пристрої Роботи Запчастини

Олена Коваленко МЕНЕДЖЕР Вийти

Андрій Кравець

← Назад

+380671234503 a.kravets@example.com м. Київ, вул. Деснянska, 22

Редагувати

Видалити

Пристрої (4)

Бренд / модель	Тип	Серійний №	Заявки
Apple MacBook Air M1	Ноутбук	APL-MBA-2021-077	1
Samsung Galaxy A54	Телефон	SAM-A54-2024-210	1
Samsung C27G55	Монітор	SAM-MONITOR-2022-1074	1
Apple iPad 9	Планшет	APP-TABLET-2022-2184	0

Історія заявок (3)

Номер	Пристрій	Тип	Пріоритет	Статус	Дата
R-2026-0004	Apple MacBook Air M1	Ремонт	Звичайний	У діагностиці	09.09.2026
R-2026-0059	Samsung C27G55	Ремонт	Звичайний	Готова	15.08.2026
R-2026-0025	Samsung Galaxy A54	Ремонт	Низький	Завершена	25.05.2026

R-2026-0004

← Назад

У діагностиці | Ремонт | Звичайний

Створено: 09.09.2026, 11:00 Менеджер: Олена Коваленко Майстер: Сергій Бондар

Редагувати Видалити Статус: Оцінка готова Скасована

Клієнт

Андрій Кравець · +380671234503 · a.kravets@example.com · м. Київ, вул. Деснянska, 22

Картка клієнта →

Пристрій

Apple MacBook Air M1 · Ноутбук · серійний № APL-MBA-2021-077 · куплений: 01.11.2021

M1, 8GB, SSD 256GB

Картка пристрою →

Опис

Чорний екран, індикатор мерехтить

Діагностика

Дата	10.09.2026
Майстер	Сергій Бондар
Висновки	Шлейф цілий, підозра на контролер яскравості. Потрібен замір живлення матриці.
Вартість	500,00 ₴

Майстер: Сергій Бондар | Дата: дд.мм.рррр | Вартість, ₴: 500

Висновки:

Шлейф цілий, підозра на контролер яскравості. Потрібен замір живлення матриці.

Примітки:

Оновити діагностику

Роботи

Робота: Робота з каталогу... | Сума, ₴: 0 | Години: 0 | Додати роботу

Робота	Години	Майстер	Статус	Сума	
Діагностика	1	Сергій Бондар	Виконано	500,00 ₴	×

Разом за роботи: 500,00 ₴

Запчастини

Запчастина: Запчастина з каталогу... | К-сть: 1 | Ціна, ₴: 0 | Додати запчастину

Запчастини ще не додані

Видалення користувача обмежено двома правилами: власний акаунт видалити неможливо (400 із поясненням), а користувача, прив'язаного до заявок, робіт чи коментарів, — теж, через onDelete: Restrict: історію аудиту зберігаємо, тому замість видалення радимо змінити роль. На скріншотах — захищені дані з погляду менеджера: список клієнтів, картка клієнта з пристроями та історією заявок, повна картка заявки. UI приховує дії, недоступні ролі, через res.locals.can; незалежно від цього, фінальний захист завжди виконує сервер.

Висновок: На цій лабораторній роботі я реалізував захищену область управління даними системи. Новий модуль /users, доступний лише адміністратору, дає повний CRUD користувачів із серверною валідацією всіх полів, хешуванням пароля bcrypt, унікальністю email та захистом від само-видалення і видалення користувачів, прив'язаних до даних (onDelete: Restrict). Додано role-aware інтерфейс: дії, недоступні ролі, приховуються з екранів через res.locals.can, а остаточний захист виконують серверні вайдери. За матрицею дозволів забезпечено CRUD-покрытие всіх 15 таблиць: довідниками та фінансами керує менеджер, роботою над заявками — майстер, користувачами — адміністратор.